Sovereign Vulnerability Proof Dossier Framework (‘QF-SOVEREIGN-BOUNTY‘

Submission Mode: Pseudonymous Security Researcher (Immunefi / Code4rena / Sherlock / Cantina / HackerOne)
Verification Engine: Local Airgapped QuantumFlex Stack (‘127.0.0.1:11434‘, ‘$0.00‘ Cloud Egress)
Assurance Gates: ‘QF-BOUNTY-01‘ (Authorization) | ‘QF-BOUNTY-02‘ (Evidence) | ‘QF-BOUNTY-03‘ (Disclosure)
Initial Research Focus: Smart-Contract Authorization, Multi-Party Quorum & Token Accounting Invariants

> **EPISTEMIC BOUNDARY (FRAMEWORK, NOT PROOF OF LIVE VULNERABILITY):**
> This document is an **evidence-generation framework**, **not** proof that a vulnerability exists in any live third-party protocol. Illustrative entries below (‘target_ma_crypto_inventory.pdf‘, sample chunk IDs, sample SHA-256 digests, example Solidity harness, and sample exposure numbers) are **synthetic local demonstration fixtures**. Before any external submission, every cited source hash, chunk boundary, vulnerable function, deterministic reproducer run, and economic impact figure must be independently verified against an explicitly authorized target.

---

0. Authorized Program Scope & Permitted Testing Proof (‘QF-BOUNTY-01‘)

- **Authorized Program / Contest URL:** ‘<Immunefi / Code4rena / Sherlock / Cantina / HackerOne Program URL>‘
- **Dated Scope Snapshot (‘scope_verified_at_utc‘):** ‘<YYYY-MM-DDTHH:MM:SSZ>‘ (Archived Program Policy SHA-256: ‘<64-hex-sha256>‘)
- **In-Scope Asset Confirmed:** ‘[ ]‘ Target contract/repository and exact commit/deployment address verified in authorized scope (‘evaluate_qf_bounty_01_authorization‘ == ‘PASS‘).
- **Permitted Testing Methods & Local Confinement:** ‘[ ]‘ Reproduction strictly confined to ‘local_foundry_fork‘ or ‘offline_source_snapshot‘ (‘127.0.0.1‘); zero live mainnet/testnet state mutation, zero autonomous exploitation, and zero live treasury-drain playbooks.
- **Individual Compliance (‘Safeguard A‘):** ‘[ ]‘ Program eligibility, KYC/tax reporting (1099/W-9), and responsible disclosure rules verified.

---

1. Vulnerability Summary & Context-Dependent Severity (‘Technical Correction D‘)

- **Title:** ‘[Severity: <Evaluated Per Program Rubric>] <Contract / Module> ? <Specific Invariant Failure>‘
- **Target Protocol & Exact Commit / Address:** ‘<Protocol Name, Chain ID, Contract Address & Git Commit SHA>‘
- **Affected Source File & Exact Lines:** ‘<path/to/Contract.sol#L00-L00>‘ (‘[<chunk_id>:p<offset>]‘)
- **Primary Research Category:**
- ‘[ ]‘ Multi-Party / Two-Person Authorization & Access-Control Invariant Failure
- ‘[ ]‘ ERC-20 / USDC Token ‘decimals()‘ Precision & Accounting Mismatch

- ‘[ ]‘ Incomplete Operation-Context Idempotency / Replay Vulnerability
- ‘[ ]‘ Runtime Descriptor / State-Transition Ordering Flaw (‘EXECUTED_FD != VERIFIED_FD‘)
- **Context-Dependent Severity Evaluation (‘assess_contextual_severity‘):**
(Never auto-classify missing dual authorization as ‘Critical‘; justify all six factors below)
1. **Actual Reachable Functionality:** ‘<unrestricted_external | privileged_mutable | timelocked_or_guarded | paused_or_unreachable>‘
2. **Required Attacker Privileges:** ‘<unauthenticated | ordinary_user | compromised_single_operator | multi_party_collusion>‘
3. **Existing Compensating Controls:** ‘<timelock delay, per-epoch velocity cap, destination allowlist, pause guardian, or none>‘
4. **Economic Exposure:** ‘<realistic reachable loss vs. theoretical TVL ceiling>‘
5. **Exploitability:** ‘<deterministic_single_tx | conditional_multi_step | unlikely_precondition>‘
6. **Program-Specific Severity Criteria:** ‘<Exact Immunefi / C4 / Sherlock rubric tier & admin-key policy cap>‘

---

2. Technical Root-Cause Analysis & Recomputed Source Integrity (‘QF-BOUNTY-02‘)

- **Actual Vulnerable Function:** ‘<ContractName.functionName(address destination, uint256 amount)>‘
- **Missing Security Invariant:** ‘<Formal predicate violated, e.g., validTwoPersonQuorum(txContext, sigA, sigB) && !consumedNonce[chainId][address(this)][nonce]>‘
- **Independent Source Hash Verification:** Raw source bytes and chunk boundaries independently recomputed locally via SHA-256 prior to static and formal analysis.
- **Illustrative Citation Fixture *(Synthetic Demo ? Replace on Live Engagement)*:**
- *Sample Dual-Control Fixture (‘target_ma_crypto_inventory.pdf‘):* Demonstrates how Athena binds a root-cause claim to an immutable page/chunk digest ‘[target_ma_crypto_inventory_c0002_d6ca4c84:p2]‘.
- *Sample Credential Hygiene Fixture (‘target_ma_crypto_inventory.pdf‘):* Demonstrates ‘PrivacyFilter‘ redaction (‘[REDACTED_CREDENTIAL]‘) alongside SHA-256 chunk provenance ‘[target_ma_crypto_inventory_c0001_a7951bbd:p1]‘.

---

3. Quantified Economic Impact: Theoretical Maximum vs. Realistically Reachable Loss

Impact Metric	Formula / Constraints	Verified Estimate
Theoretical Maximum Exposure	Unthrottled total value held by ‘<Contract>‘ at snapshot block ‘<N>‘	‘<$X.XX USD / Token Units>‘
Realistically Reachable Loss	Bounded by ‘<per-epoch cap, liquidity depth, timelock cancellation window, or privilege boundary>‘	‘<$Y.YY USD <= Theoretical Max>‘
Compensating Control Offset	Value protected by active pause/timelock/allowlist mechanisms	‘<$Z.ZZ USD>‘

> **Financial Reserve Safeguard (‘Safeguard C‘):** Potential or pending bug bounty awards

  never count toward Operator household reserves ($R_{\text{verified liquid}} \ge 6O$).
  Bounty proceeds enter ‘Bucket 1‘ / ‘Bucket 3‘ only after actual receipt, settlement
  clearance, tax-reserve allocation, and Track 0 reconciliation.

---

4. Deterministic Local Proof-of-Concept & Sovereign Bounty Workflow

4.1 Commercial & Assurance Pipeline (‘QF-SOVEREIGN-BOUNTY‘)

‘‘‘text
QF-SOVEREIGN-BOUNTY
|
v
Authorized Scope Gate (QF-BOUNTY-01)
|
v
Source Acquisition -> Independent SHA-256 & Chunk Verification
|
v
Athena Local Static Analysis (127.0.0.1:11434, $0.00 Cloud Egress)
|
v
Foundry Local Snapshot Verification -> F* / Invariant Verification
|
v
Independent Evidence Review (QF-BOUNTY-02) -> Contextual Impact & Severity Assessment
|
v
PrivacyFilter Sanitization -> Mandatory Human Submission Approval (QF-BOUNTY-03)
|
v
Authorized Responsible Disclosure
‘‘‘

4.2 Local Snapshot Reproducer & Remediation Regression Harness (Synthetic Example)

‘‘‘solidity
// Local-only verification (never broadcast to live networks):
// forge test --match-contract EscrowAuthorizationInvariantTest -vvv
contract EscrowAuthorizationInvariantTest is Test {
function testBaselineAndSingleSignerFailure() public {
// 1. Verify token contract decimals() on target chain before scaling (1 USDC == 10^6 base
  units)
assertEq(usdc.decimals(), 6);
uint256 initialVaultBalance = 1_000_000 * (10 ** uint256(usdc.decimals()));
assertEq(usdc.balanceOf(address(escrow)), initialVaultBalance);

// 2. Demonstrate invariant failure in local snapshot only (zero live drain instructions)
vm.prank(compromisedSingleOperator);
escrow.sweepToAllowlistedVault(recoveryVault, initialVaultBalance);
assertEq(usdc.balanceOf(address(escrow)), 0);

```
}

function testRemediationRestoresTwoPersonInvariant() public {
// 3. Regression test: remediated contract rejects single-signer or replayed context
uint256 amount = 1_000_000 * 1e6;
vm.prank(compromisedSingleOperator);
vm.expectRevert(RemediatedEscrow.DistinctTwoPersonQuorumRequired.selector);
remediatedEscrow.executeWithQuorum(txContext, sigOperatorAOnly, sigOperatorAOnly);
}
}
```

---

5. Recommended Fail-Closed Remediation & Technical Controls

1. **Two-Person Authorization (‘Technical Correction A‘ ? Beyond Hardware Signatures Alone):**

Hardware-backed signatures (‘CredTwoManAttestation‘) alone do not establish two-person control if one identity holds both tokens or replays stale approvals. Enforce all six invariants (‘src/bounty_assurance.py::verify_two_person_authorization‘):

- **Two distinct authorized identities** (‘signer_a_id != signer_b_id‘).
- **Independent signing credentials** (‘credential_a_id != credential_b_id‘, distinct public keys).
- **Explicit transaction payload binding** (‘chain_id‘, ‘contract_address‘, ‘operation_type‘, ‘destination‘, ‘amount_base_units‘, ‘nonce‘, ‘expires_at_unix‘).
- **Nonce and expiry validation** (strictly bounded TTL window).
- **Replay protection** (atomic consumption of ‘(chain_id, contract_address, nonce)‘ and payload digest).
- **Revocation handling** (immediate fail-closed rejection of revoked identities or credentials).

2. **Verified Per-Contract Token Precision (‘Technical Correction B‘):**

While canonical USDC uses 6 decimals ($1\text{ USDC} = 10^6\text{ base units}$, verified at ‘0x833589fCD6eDb6E08f4c7C32D4f71b54bdA02913‘ on Base Mainnet and ‘0x036CbD53842c5426634e7929541eC2318f3dCF7e‘ on Base Sepolia), **never assume every ERC-20 token uses 6 decimals**. Query and assert ‘decimals()‘ on the exact token contract and chain deployment (‘verify_token_decimal_precision‘), and compile Solidity with ‘evm_version = "paris"‘.

3. **Full-Operation-Context Deterministic Idempotency (‘Technical Correction C‘):**

Do not derive transaction idempotency keys from ‘sha256(blockHash)‘ alone. Bind deterministic ‘RFC 4122 UUID v4‘ identifiers (‘derive_contextual_idempotency_key‘) to the complete operation context:

- ‘chain_id‘, ‘contract_address‘, ‘operation_type‘, ‘nonce‘, ‘destination‘, and ‘amount_base_units‘ (plus ‘proof_block_hash‘ where applicable) to distinguish separate operations in the same block and prevent cross-context replay.

---

6. Independent Validation (‘QF-BOUNTY-01‘ .. ‘QF-BOUNTY-03‘)

Verification	Acceptance Condition	Gate	Verified Status

Scope verification	Explicit dated program authorization & local-only testing rules confirmed	‘QF-BOUNTY-01‘	‘[ ] PASS‘
Source verification	Independently recomputed SHA-256 & chunk boundaries match target files	‘QF-BOUNTY-02‘	‘[ ] PASS‘
Reproducer determinism	Identical SHA-256 test output across repeated local snapshot runs (‘>= 2‘)	‘QF-BOUNTY-02‘	‘[ ] PASS‘
Baseline behavior	Establishes expected normal contract behavior prior to remediation	‘QF-BOUNTY-02‘	‘[ ] PASS‘
Remediation regression	Regression test demonstrates reported security invariant is restored	‘QF-BOUNTY-02‘	‘[ ] PASS‘
Impact validation	Realistic vs. theoretical economic exposure supported by reproducible math	‘QF-BOUNTY-02‘	‘[ ] PASS‘
Disclosure review	‘PrivacyFilter‘ clean, zero live-drain instructions, mandatory human sign-off	‘QF-BOUNTY-03‘	‘[ ] PASS‘

- **Mandatory Human Submission Approval (‘QF-BOUNTY-03‘):**
- **Approved By (‘human_approver_id‘):** ‘<rahshaun_chambers>‘
- **Approved At (‘approved_at_utc‘):** ‘<YYYY-MM-DDTHH:MM:SSZ>‘
- **Submission Gate Decision:** ‘BLOCKED UNTIL ALL 7 CHECKS == PASS AND HUMAN_SUBMISSION_APPROVED == TRUE‘

---

7. Deterministic Citation & Cryptographic Provenance Ledger (‘AT-RDOS-02‘)

(Synthetic demonstration ledger entries shown below; replace with target-specific recomputed digests on live engagements)

Chunk ID	Source Artifact	Page / Offset	Recomputed Chunk SHA-256 Digest	Fixture Status
‘target_ma_crypto_inventory_c0002_d6ca4c84‘	‘filings/target_ma_crypto_inventory.pdf‘	p. 2	‘d6ca4c8408449b037843aaf775077e69fcf18d7227d0a340631fa158c3690d1e‘	‘SYNTHETIC_DEMO‘
‘target_ma_crypto_inventory_c0001_a7951bbd‘	‘filings/target_ma_crypto_inventory.pdf‘	p. 1	‘a7951bbde5bc672ac7a8278d09522ae7e6968d22f30b6e7d9ef0a389bc6ee53c‘	‘SYNTHETIC_DEMO‘